Лекція 4

Хеш-функції. Цифровий підпис з хеш-функцією.

4.1. Недоліки можливого підписування повідомлень без хеш-функцій.

Загалом хеш-функції перетворюють будь-яку послідовність в коротке її хеш-значення.

Розглянемо варіант цифрового підпису RSA для довгих повідомлень без хеш-функцій.

Алгоритм 4.1. Формування цифрового підпису RSA без хеш-функції користувачем А, має криптосистему RSA з відкритим ключем (n, e) і таємним ключем d.

1. Розбиває M на блоки: $M_1 M_2 \dots M_t$ де $|M_i| < n$, $i = 1,\dots, t$.
2. Обчислює цифровий підпис для кожного з блоків окремо
   $M_i{}^d \bmod n = S_i$, $i = 1,\dots, t$.
3. Формує підписане повідомлення $(M, S_1, S_2, S_3, \dots, S_t)$.

Недоліки цього способу підписування повідомлення.

1) *Трудоємність.*

Очевидно, що чим більше блоків необхідно підписати, тим більше часу потрібно витратити (пропорційно числу блоків). Підписане повідомлення стає вдвічі довше. Тому даний варіант не є практичним з обчислювальної точки зору.

2) *Атаки перестановкою і видаленням блоків.*

Оскільки блоки підписуються незалежно, криптоаналітик E може видаляти та переставляти як завгодно блоки повідомлення M_i і відповідні блоки цифрового підпису S_i без порушення правильності підпису, продукуючи повідомлення з правильним цифровим підписом, які А ніколи не підписував і не підписав би.

3) *Мультиплікативні атаки.*

Нехай А підписав два повідомлення $(M_1,\ S_1)$ і $(M_2,\ S_2)$. Криптоаналітик E формує неправдиве повідомлення з правдивим цифровим підписом

$(M_3,\ S_3)$, де $M_3 = M_1 \times M_2 \bmod n$, $S_3 = S_1 \times S_2 \bmod n$

При перевірці цифрового підпису маємо:

$$S_3{}^e \bmod n = (S_1 \times S_2)^e \bmod n = (M_1{}^d \times M_2{}^d)^e \bmod n =$$

$$= (M_1{}^{de} \times M_2{}^{de}) \bmod n = (M_1 \times M_2) \bmod n = M_3$$

Тобто підпис правильний.

Взагалі кажучи, з будь-якої кількості (M_i, S_i), $i = 1,\ldots, t$, підписаних повідомлень (навіть з одного), можна скласти фальшиві повідомлення з правильним цифровим підписом $(\widetilde{M}, \tilde{S})$, де

$$\widetilde{M} = (\prod_{i=1}^{t} M_i{}^{\alpha_i}) \bmod n\,, \quad \tilde{S} = (\prod_{i=1}^{t} S_i{}^{\alpha_i}) \bmod n,$$

α_i - будь-які цілі невід'ємні числа не рівні одночасно всі нулю.

Перевірка цифрового підпису покаже, що підпис вірний. Таким чином можна обчислити скілки завгодно фальшиві повідомлення з правильним цифровим підписом $(\widetilde{M}, \tilde{S})$. Але усі ці повідомлення неможливо створити з бажаним змістом, усі вони будуть псевдовипадковими послідовностями.

4) *Атака з неявним використанням таємного ключа*.

Алгоритм 4.2. Атака з неявним використанням таємного ключа криптоаналітиком E.

Нехай користувач A має криптосистему RSA з відкритим ключем (n, e) і таємним ключем d і E хоче підписати у A повідомлення M, яке вигідне криптоаналітику.

1. Вибирає деяке число $r, (r, n) = 1, 1 < r < n$.
2. Обчислює $\widetilde{M} = r^e \cdot M \bmod n$.
3. Відправляє повідомлення $\widetilde{M}$ для цифрового підпису A.
4. Якщо A підписав запропоноване повідомлення $\widetilde{M}$, то E отримує підписане повідомлення $(\widetilde{M}, \tilde{S})$ та може обчислити підпис початкового вигідного для E повідомлення M:

$$\tilde{S} = \widetilde{M}^d \bmod n = r^{de} \cdot M^d \bmod n = r \cdot M^d \bmod n,$$

$$S = M^d = \tilde{S} \cdot r^{-1} \bmod n.$$

5. Формує вигідне для нього підписане повідомлення (M, S).

Але криптоаналітик E в алгоритмі 4.2 тільки одне з повідомлень M або $\widetilde{M}$ може вибрати змістовним, друге буде випадковим.

Всі наведені атаки на цифровий підпис не будуть працювати, якщо цифровий підпис створюється з використання хеш-функції зі специальними криптографічними властивостями.

4.2. Хеш-функції і їх криптографічні властивості.

Термін хеш-функція (або функція хешування) виник в теорії складності обчислень, де таким терміном позначали функцію, яка стискає строку чисел довільного розміру в строку чисел фіксованого розміру та ймовірність збігу хеш-значень різних послідовностей чисел настільки мала, що нею можна знехтувати. Хеш-значення можно розглядати як індивідуальний код, короткий ідентифікатор довгої послідовності чисел. Хеш-функції використовувались, наприклад, в алгоритмах пошуку даних (можливо дуже великих) по хеш-образам їх перетворень з допомогою такої стискаючої функції. В криптографії хеш-функції використовуються

- для створення стислого образу повідомлення, документа в алгоритмах цифрового підпису,
- для захисту паролів в схемах автентифікації,
- в механізмах генерації паролів, ключових параметрів,
- для побудови кода автентифікації повідомлень,
- для контроля за процесами обчислення, криптографічних перетворень.

Зазвичай в криптографії інформація представляється у двійковій формі і хеш-функція – це стискаюче перетворення послідовності будь-якої довжини в алфавіті $\{0, 1\}$ в послідовність нулів та одиниць фіксованої довжини, яке певним складним чином пов'язано з початковою послідовністю. На властивості хеш-функцій при криптографічних застосуваннях накладаються більш сильні вимоги, бо від них залежить надійність відповідних криптографічних алгоритмів та протоколів.

Розглянемо формальне означення хеш-функції. Будемо позначати $\{0,1\}^* = \bigcup_{n=0}^{\infty}\{0,1\}^n$ множину всіх двійкових послідовностей; $h(X),\ X \in \{0,1\}^*$, хеш-функцію, $H = h(X)$ – хеш-значення або хеш-образ, $h_n(X),\ X \in \{0,1\}^n$, - хеш-функцію двійкової послідовності довжини n, яку будемо називати також повідомленням.

Означення 4.1. Хеш-функцією в криптографії називається відображення

$$h(X)\colon \{0,1\}^* \to \{0,1\}^m,\ m = \text{const},\ m \in \mathbb{N}\ ,$$

яке розглядається як послідовність функцій

$$h(X) = \{\ h_n(X)\colon \{0,1\}^n \to \{0,1\}^m, m = \text{const}, m \in \mathbb{N}, n = 1,2,3,\dots\},\ (4.1)$$

і має такі властивості:

1. $\forall\, X \in \{0,1\}^*$ хеш-значення $H = h(X)$ обчислюється швидко, тобто існує алгоритм поліноміальної часової складності від n. На практиці це означає, що хеш-значення швидко знаходиться для послідовностей (повідомлень) навіть дуже великої, але все-таки реальної довжини n .
2. Хеш-функція чутлива до будь-якої зміни вхідної послідовності. Ця властивість формалізується в термінах таких криптографічних властивостей булевих функцій $h_n(X)$, як строгий лавинний ефект k-го порядку, $k = 0,1,2,\dots,n-1$, лавинний ефект у середньому різного порядку та мірою відхилень від відповідних характеристик.
3. $h(x)$ – обчислювально одностороння функція, тобто для будь-якого $H \in \{0,1\}^m$

   неможливо знайти хоча б одне M, таке що $H = h(M)$.

   Приклад 4.1. Нехай m = 256, $|M|$ = 500. Тоді в середньому $\forall\ H = h(M)$ існує $2^{500}/2^{256}=2^{244}$ можливих M, але зустрічаються вони дуже рідко серед інших. Не зважаючи на таку їх кількість, знайти хоча б одне повідомлення-прообраз обчислювально і випадково неможливо.
4. Слабка стійкість до колізій, тобто для кожного фіксованого повідомлення M неможливо знайти M', $M' \neq M$ таке, що $h(M) = h(M')$.
5. Сильна стійкість до колізій, тобто неможливо знайти хоча б одну пару повідомлень (M,M') таку, що $h(M) = h(M')$.

Означення 4.2. Хеш-функція, яка має властивості 1-4 називається слабкою односторонньою хеш-функцією.

Означення 4.3. Хеш-функція, яка має властивості 1-5 називається сильною односторонньою хеш-функцією.

Зауваження 4.1. Зазвичай довжина виходу хеш-функції m складає 128, 160, 192, 256 або 512 біт. Найпоширенішими є хеш-функції з довжиною m = 160 або 256 біт. На цих довжинах досягається компроміс між стійкістю до колізій та швидкістю обчислення хеш-функції.

4.4. Цифровий підпис повідомлення довільної довжин з хеш-функцією в криптосистемах *RSA та Ель – Гамаля.*

Цифровий підпис RSA з хеш – функцією $h(X)$.

Побудова системи *ЦП* RSA така ж як і побудова системи шифрування RSA, тільки додатково вибирається і оголошується хеш-функція. Нехай користувач A має RSA з відкритим ключем (n, e), секретним d, та відкриту хеш-функцію $h(X)$. Вважаємо, що довжина хеш-значення $m = |h(X)|$ така, що $2^m \leq n$, що при довжинах вихідного рядка хеш-функцій, які використовуються, і модулів RSA завжди виконується.

Формування ЦП до повідомлення M довільної довжини користувачем A.

1. Обчислює $H = h(M)$.
2. Обчислює $S = H^d \bmod n$.
2. Формується підписане повідомлення: (M, S)

Перевірка ЦП підписаного повідомлення (M, S) в RSA користувачем B.

1. Розділяє $(M, S) \rightarrow M, S$.
2. Обчислює $H = h(M)$.
3. Перевіряється рівність $S^e \bmod n = H$ (“так” або “ні”).

Стійкість цифрового підпису RSA базується на складності задачі факторизації великих чисел.

Криптосистеми ЦП Ель – Гамаля з хеш-функцією.

Побудова криптосистеми ЦП Ель – Гамаля з хеш-функцією користувачем A.

1. Вибирає: велике просте p, примітивний елемент α, випадкове $k, 1 < k < p - 1$.
2. Обчислює $y = \alpha^k \bmod p$.
3. Оголошує відкритий ключ для перевірки ЦП (p, α, y) та хеш-функцію $h(X)$.

При цьому, k – секретний ключ A для формування ЦП

Формування ЦП для повідомлення M довільної довжини з хеш – функцією $h(X)$ користувачем A .

1. Вибирає випадкове x_M, $1 < x_M < p-1, (x_M, p-1) = 1$.
2. Обчислює $r = \alpha^{x_M} \bmod p$ та $H = h(M)$.
3. Розв'язує відносно S рівняння $H \equiv (kr + x_M S) \bmod (p-1)$. Знаходить $S = (H - kr)x_M^{-1} \bmod (p-1)$.
4. Формує підписане повідомлення (M, r, S), пара (r, S) - цифровий підпис.

Перевірка ЦП підписаного повідомлення (M, r, S) користувачем B.

Користувач *B* перевіряє рівність:

$$y^r r^S \bmod p = \alpha^{h(M)} \bmod p \text{ (так, або ні).}$$

Дійсно, якщо немає умисних або випадкових спотворень, то дана рівність буде виконуватися:

$$y^r r^S \bmod p = \alpha^{kr} \alpha^{x_M S} \bmod p = \alpha^{kr + x_M S} \bmod p = \alpha^{t(p-1)+H} \bmod p$$

$$= (\alpha^{p-1})^t \alpha^H \bmod p = \alpha^H \bmod p = \alpha^{h(M)} \, mod \, p.$$

Зауваження 4.2. Для різних M_1 і $M_2, M_1 \neq M_2$, параметри *ЦП* x_{M_1} і x_{M_2} повинні бути різними. Тобто, x_{M_i} не повторяються.

Атака. Припустимо, що для *ЦП* повідомлень M_1 і $M_2, M_1 \neq M_2$ підписант *A* вибрав $x_{M_1} = x_{M_2} = x$.

Криптоаналітик *E* зразу це виявляє, оскільки підписані повідомлення будуть (M_1, r_1, S_1)і (M_2, r_2, S_2), які мають такі однакові значення

$$r_1 = r_2 = \alpha^x \, mod \, p = r.$$

Тоді *E* обчислює хеш-функцію

$$H_i = h(M_i), \qquad i = \{1, 2\}$$

і розв'язує систему рівнянь відносно *k і x*

$$\begin{cases} H_1 = (kr + xS_1) \bmod (p-1), \\ H_2 = (kr + xS_2) \bmod (p-1) \end{cases}$$

Система легко розв'язується і криптоаналітик E зламує криптосистеми *ЦП* Ель-Гамаля: знаходить секретний ключ і може підписувати за користувача А повідомлення, документи, не маючи на це прав. Звичайно, через деякий час компрометація ключа системи буде виявлена, але за цей час криптоаналітик E зможе досягти певних успіхів і вигід від використання знайденого секретного ключа. Тут ситуація дещо відрізняється від компрометації ключа шифрування, виявити яку законним користувачам значно складніше (приклад: історія використання і криптоаналізу основної криптосистеми вермахту Enigma під час Другої світової війни).

4.5. Стандарт електронного цифрового підпису DSA.

У багатьох країнах існують стандарти електронного цифрового підпису. Наприклад, російський державний стандарт ГОСТ Р34.10-94, стандарт США FIPS 186. Американський стандарт DSA (Digital Signature Algorithm) був прийнятий у 1991р., російський - в 1994 р. В основі обох лежить алгоритм, який є варіацією цифрових підписів Ель-Гамаля і Шнора.

Побудова криптосистеми ЦП DSA
з хеш-функцією користувачем А.

Алгоритм DSA використовує такі параметри:

p – просте число довжиною L біт, де L кратно 64 і лежить у діапазоні від 512 до 1024;

q - 160-бітовий простий множник числа $p-1$,

$$g = h^{\frac{p-1}{q}} \bmod p,$$

де h будь-яке число менше $p-1$, для якого $h^{\frac{p-1}{q}} \bmod p > 1$;

x число, що менше q,

$$y = g^x \bmod p.$$

Стандарт DSA передбачає використання $h(M)$ - хеш-функції SHA.

Параметри p, q, g є відкритими і можуть бути спільними для користувачів мережі. Секретним ключем є число x для формування ЦП, а y є відкритим ключем для перевірки ЦП.

Формування ЦП для повідомлення M довільної довжини з хеш – функцією $h(X)$ користувачем A .

Нехай є повідомлення M, яке потрібно підписати. Формування цифрового підпису виконується за кроками:

1. Користувач А генерує випадкове число k, яке менше q.
2. Обчислює

$$r = (\mathrm{g}^k \bmod p) \bmod q,$$

$$s = (k^{-1}(h(M) + xr)) \bmod q.$$

Цифровим підписом є пара (r, s), а підписане повідомлення має вигляд (M, r, s).

Перевірка ЦП підписаного повідомлення (M, r, s) користувачем B.

Користувач ***B*** для перевірки ЦП обчислює числа:

$$w = s^{-1} \bmod q\ ,$$

$$u_1 = (\ h(M) \cdot w) \bmod q,$$

$$u_2 = (rw) \bmod q,$$

$$v = \left((\mathrm{g}^{u_1}\ \mathrm{y}^{u_2}) \bmod p\right) \bmod q.$$

Якщо $v = r$, то підпис верифіциовано, тобто ЦП вірний, повідомлення не спотворено і підписано користувачем ***B.***

Дійсно, якщо не було випадкових або навмисних спотворень, то

$$v = \left((\mathrm{g}^{u_1}\ \mathrm{y}^{u_2}) \bmod p\right) \bmod q =$$

$$\left(\left(\mathrm{g}^{(\ h(M) \cdot s^{-1}) \bmod q}\ \mathrm{y}^{(rs^{-1}) \bmod q}\right) \bmod p\right) \bmod q =$$

$$= \left(\left(\mathrm{g}^{k((h(M)+xr)^{-1}(h(M)+xr)) \bmod q}\ \right) \bmod p\right) \bmod q =$$

$$= (\mathrm{g}^k \bmod p) \bmod q = r$$

Стійкість цифрових підписів Ель-Гамаля і DSA базується на складності задачі дискретного логарифмування. На відміну від цифрового підпису RSA цифрові підписи Ель-Гамаля і DSA можуть бути реалізовані з використанням математичного апарату еліптичних кривих, що дає суттєві переваги в практичній швидкості реалізації алгоритмів формування і перевірки ЦП при однаковій стійкості систем цифрового підпису.